JP Crypto-ISAC

Grassroots-Driven Approaches to Information Sharing: A Bottom-Up Perspective

October 15, 2025 @BGIN #13

Miho Hirashita, operation manager of JPCrypto-ISAC
Georgetown University Law Center LL.M. of 2026

From Silos to Sharing: The JPCrypto-ISAC Model

Self-help

28 registered VASPs

Mutual aid

JFSA

Government support

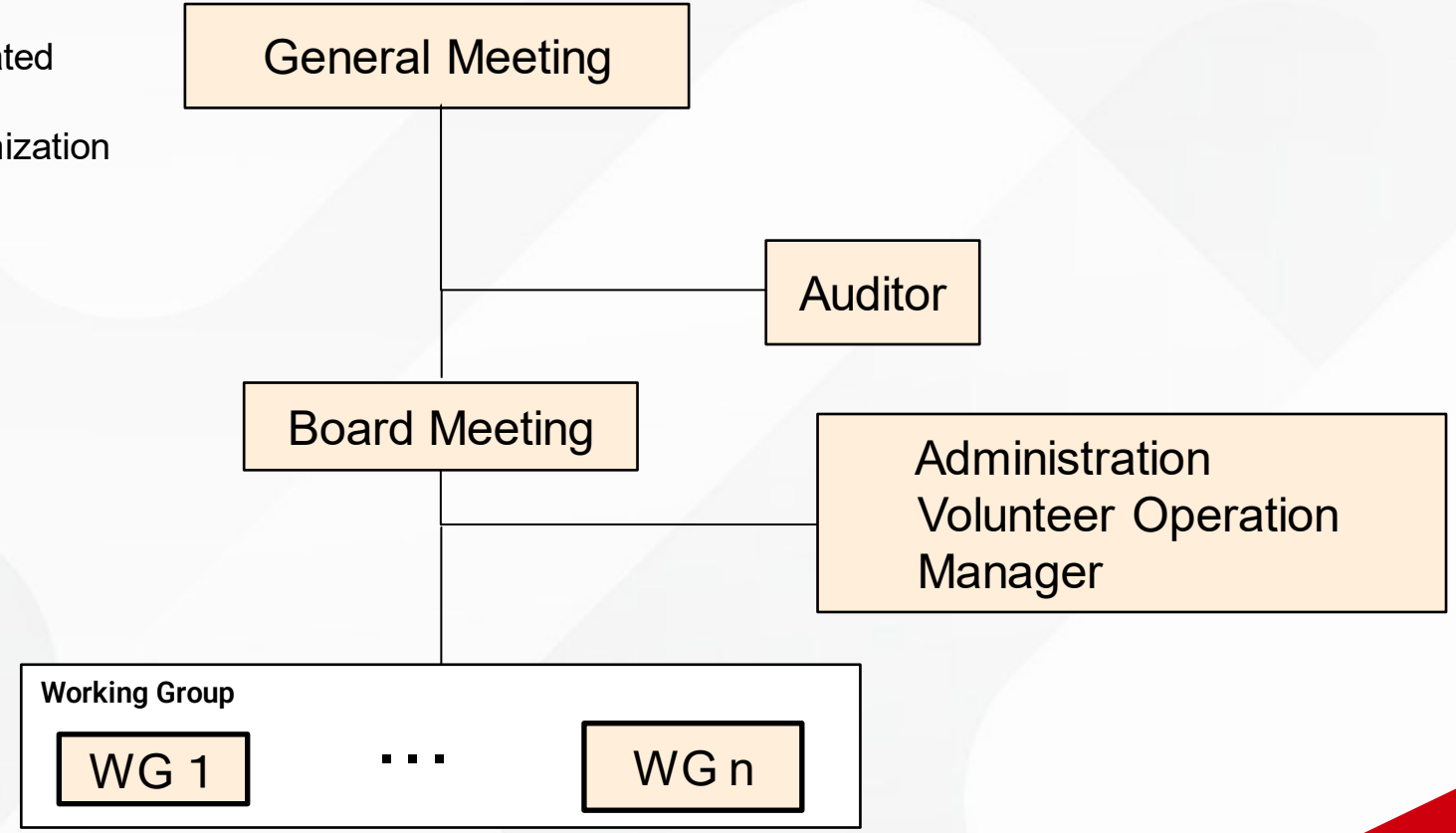
© JPCrypto-ISAC All Right Reserved.

The Birth of JPCrypto-ISAC: Responding to a Growing Need

Name	**General Incorporated Association JPCrypto-ISAC**		
Establishment	**January 17, 2025**		
Membership (as of Sep 30,2025)	**Regular members**	JFSA registered VASPs	**11** of 28 (Including companies that are effectively dormant)
	Support members	Third Party Wallet vendors	**2**
		Stablecoin issuer	**1**
		Cloud Infra Vendor	**1**
		Audit Firms	**2**
		Other vendors	**3** **(Total 9)**
Structure	Statutory Bodies Optional Organization	Board Member 3, Auditor 1, Part-Time Staff 1, External Advisor 3	
Main incidents	May 2024	**The DMM Bitcoin Hack**: A $305 Million Crypto Heist in Japan	
	Feb 2025	**The Bybit Hack**: A $1.5 Billion Ethereum Breach	
	May 2025	Joined IPA J-CSIP. Began **distributing vulnerability information** to members.	
	June 2025	Launched the **Third-Party Risk Management Working Group**	

Organization Structure (Statutory requirements)

General Incorporated Association
= Non-profit organization



© JPCrypto-ISAC All Right Reserved.

Basic Comparison on the Economy

As of 2025	Japan	US
Nominal GDP (USD Trillion)	4.19 (about **13.7%** of the US GDP), 5th global GDP	30.51
Household Financial Assets (USD Trillion)	14.9 (about **13%** of the US's)	115.5
Per Capita Financial Assets (USD)	118,000(about **1/3** of the US's)	348,000
Asset Composition: Cash & Deposits (%)	50%(about **3.85 times** of the US's)	13%

© JPCrypto-ISAC All Right Reserved.

Digital Asset Market Comparison

As of 2025	Japan	US
Spot Trading Volume (USD Billion)	13.1 (about **5.95%** of the US's)	220.0
Margin Trading Volume (USD Billion)	10.4 (about **5.78%** of the US's)	180.0
Custody Balance (USD Billion)	34.5(about **6.9%** of the US's)	500.0
Number of Accounts (Million)	12(about **1/4** of the US's)	50

© JPCrypto-ISAC All Right Reserved.

Capabilities of Domestic VASPs in Japan

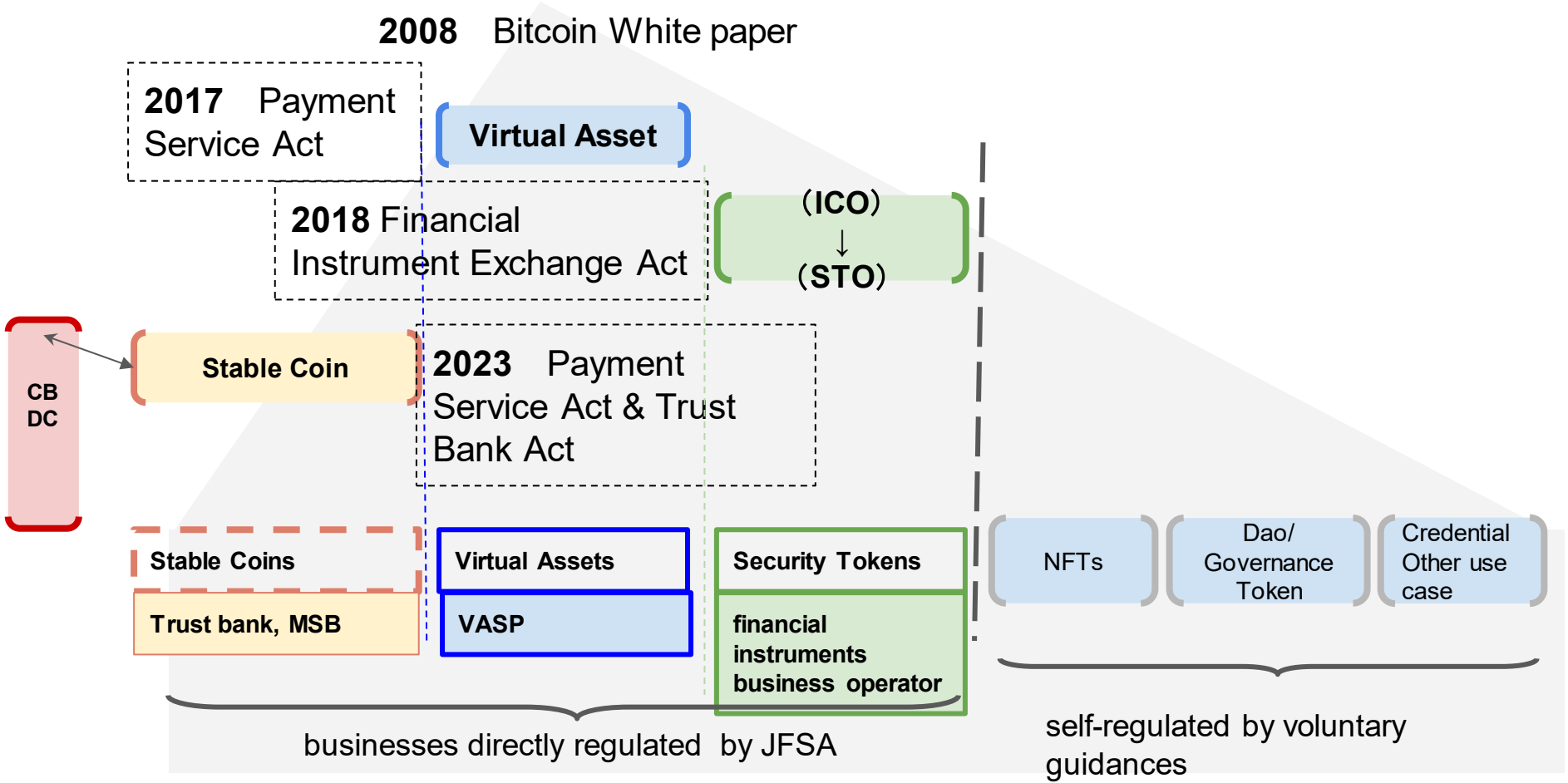
(USD million)

	VASPs	Customer Crypto Assets Under Custody	Net Profit for the Current Term
1	bitFlyer	7266	4.9
2	CoinCheck	5868.6	1.7
3	BitBank	4481	1.4
4	SBIVC Trade	2718	5.3
5	GMO Coin	2665	1.6

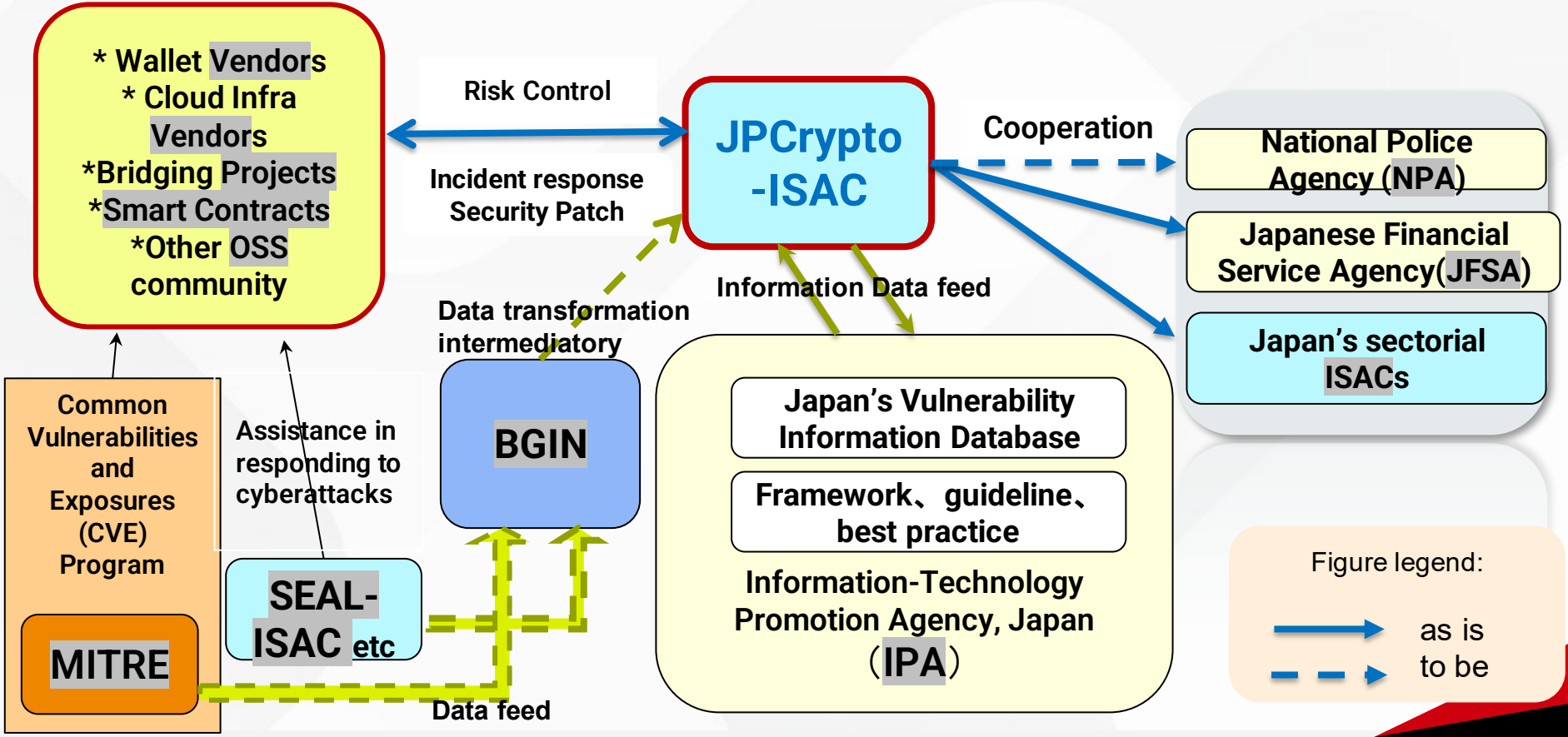
coinbase	328,000	2,579
Binance	160,000	Not disclosed

© JPCrypto-ISAC All Right Reserved.

Token use case expansion and Token Taxonomy in Japan

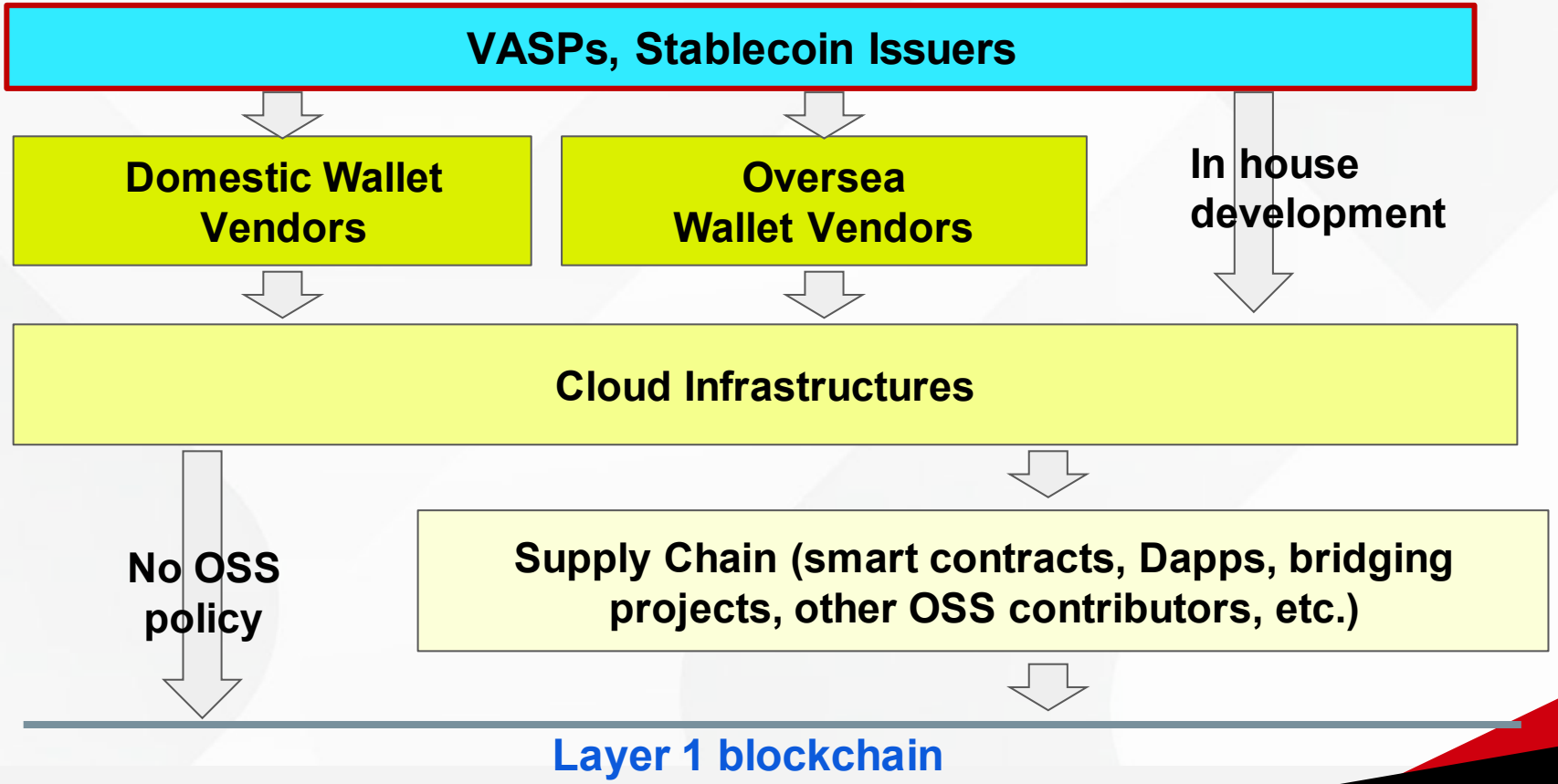


Essential Structure for JPCrypto-ISAC Operation



© JPCrypto-ISAC All Right Reserved.

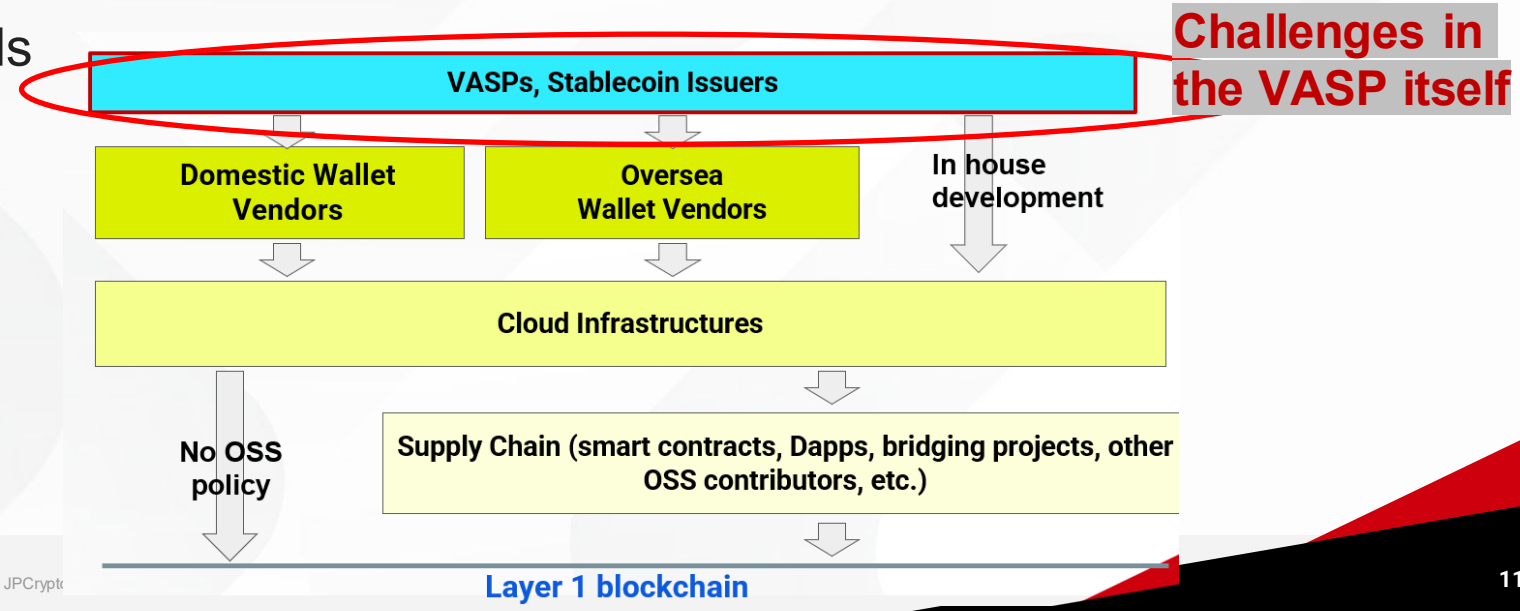
Supply Chains in Blockchain-Based Systems



© JPCrypto-ISAC All Right Reserved.

Challenge in Auditing the Crypto Asset Ecosystem

- Lack of **dynamic audit/evaluation** methods
- Annual audits can't keep up with **rapid changes**
- Static audits miss **evolving risks**→ Need flexible guidelines over fixed standards

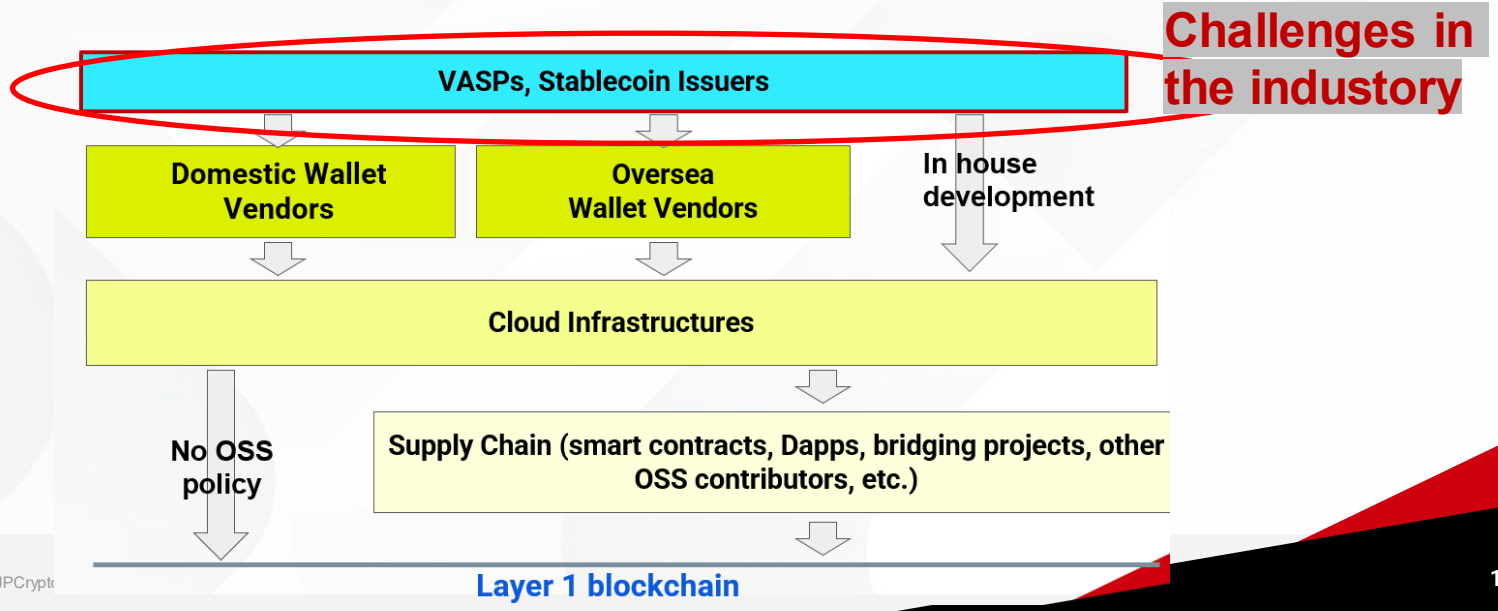


© JPCrypt

Need for Neutral Third-Party Evaluation and Information Sharing Framework

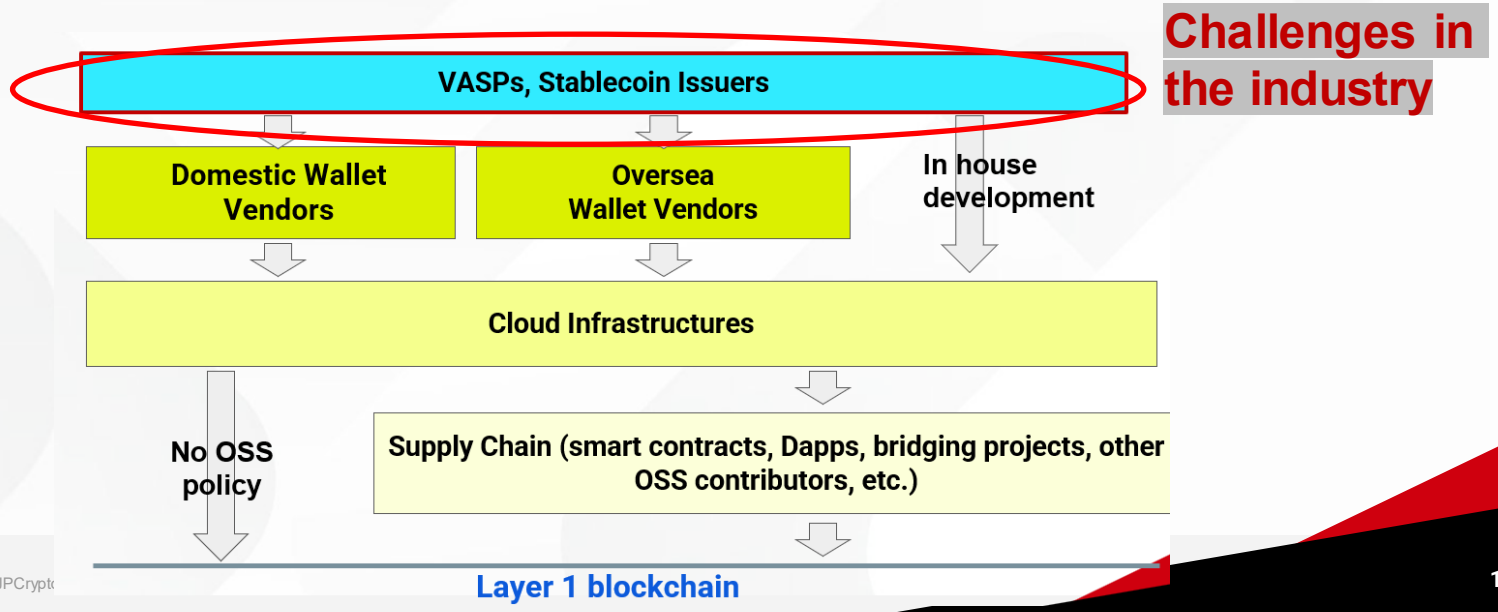
- **Limited Audit Coverage** by the self regulatory bodies

  → Relying solely on VASPs means **no internal audit** will be **conducted** by the company.



Challenge in Talent Development

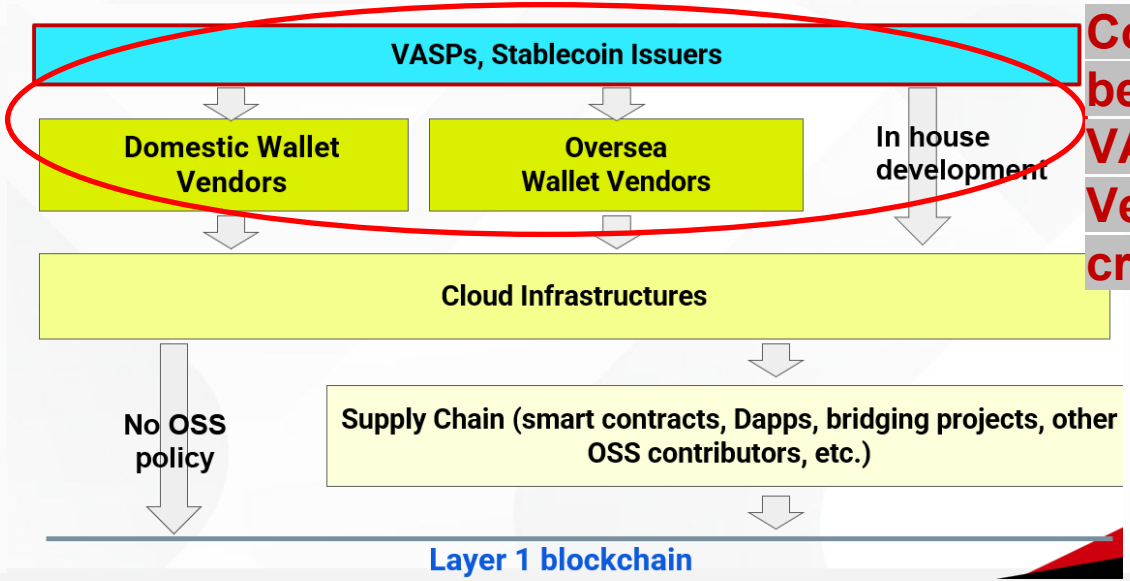
- **Shortage of Skilled** Security Professionals
- Urgent Need for **International Standardization** and **Domestic Talent** Development (Due to cross-border nature of crypto assets)



© JPCrypt

Challenge in Key & Wallet Management

- No standardized operations, Reactive Measures **Only After Incidents**
- **Trial-and-error** leads to design flaws
- Lack of **log tracking & disaster recovery planning**→ need for sharing on operational good practice



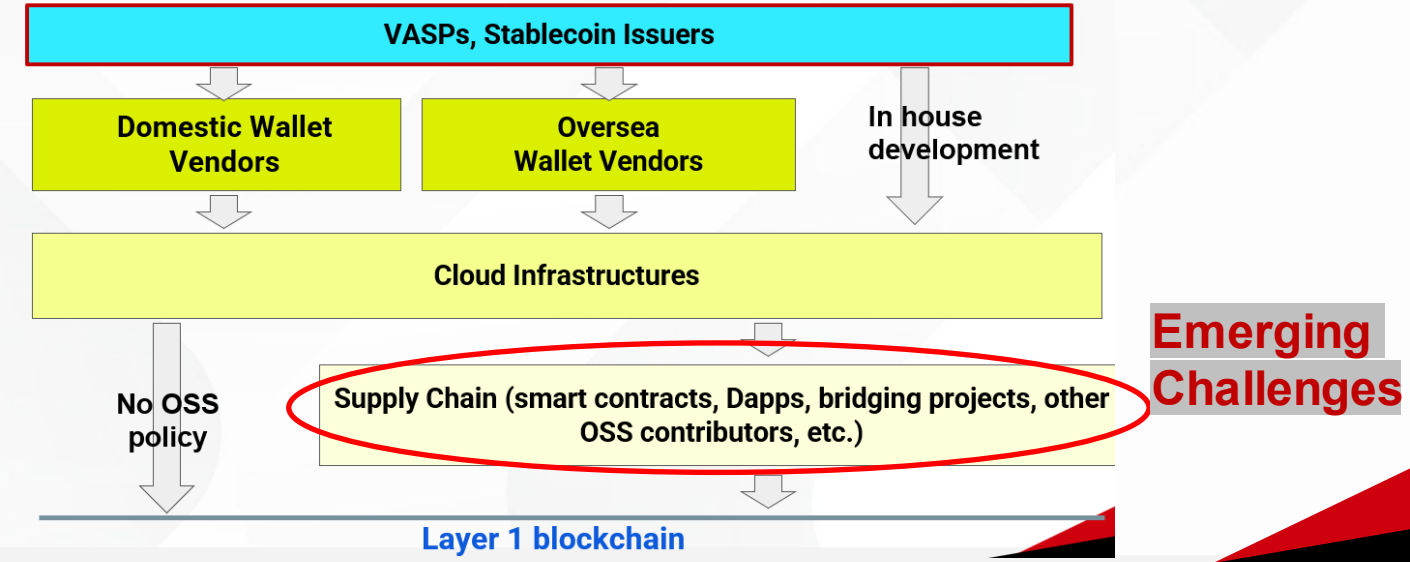
Collaboration between VASPs and Vendors are critical

© JPCrypto-ISAC All Right Reserved.

Challenges in Bridges, Smart Contracts and other OSS projects

- **No established risk models**
- Poor transparency in **access rights & upgrades**

→Mindset shift and incentives for OSS contributors are essential

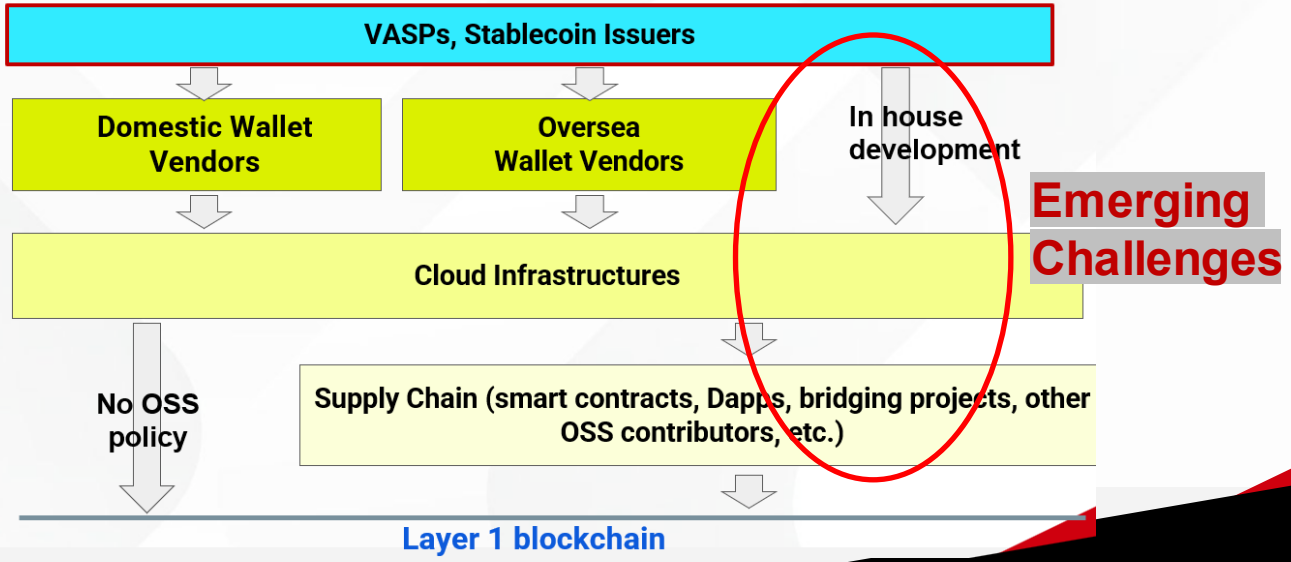


© JPCrypto-ISAC All Right Reserved.

Challenge in Continuity and Visibility of Supply Chain Audits

- Alignment with **International SBOM Standards** is critical
- Lack of **Learning from Past** Incidents

  → Need to share best practices (collection & utilization methods) across the industry



Taking the First Step Amid Challenges :the Third-Party Risk Management WG

- **Key Challenges to Address by the Third-Party Risk Management WG**
  - Capturing rapid changes in the business environment beyond annual audits
  - Promoting audit practices despite weak audit culture among VASPs
  - Raising industry-wide security levels amid a shortage of skilled professionals
  - Standardizing key management operations and sharing best practices
  - Tackling the complexity of supply chain management

© JPCrypto-ISAC All Right Reserved.

Guidelines, Self-Regulations and Practices for VASPs

Payment Service Act (PSA)

Administrative Guidelines issued by JFSA

Refer to

Cybersecurity Guidelines for the Financial Sector

Refer to

FISC Security Guidelines on Computer Systems

FFIEC, FDIC, OCC Guidelines

Refer to

NIST Frameworks

JPCrypto-ISAC Third-Party Risk Management Practice and Tool kit

© JPCrypto-ISAC All Right Reserved.

Deliverables of WG : Launched of the best practice and tool kit in Sep.

- ✓ Collection of Best Practices for Applying Security Standards
- ✓ Standardized Checklist for Vendor Selection
- ✓ Standardized System Architecture Diagrams and Key Questions for Third-Party Vendor Hearings to Understand Potential Attack Points
- ✓ Standard Addendum to Master Service Agreements Granting Audit Rights to Contractors

© JPCrypto-ISAC All Right Reserved.

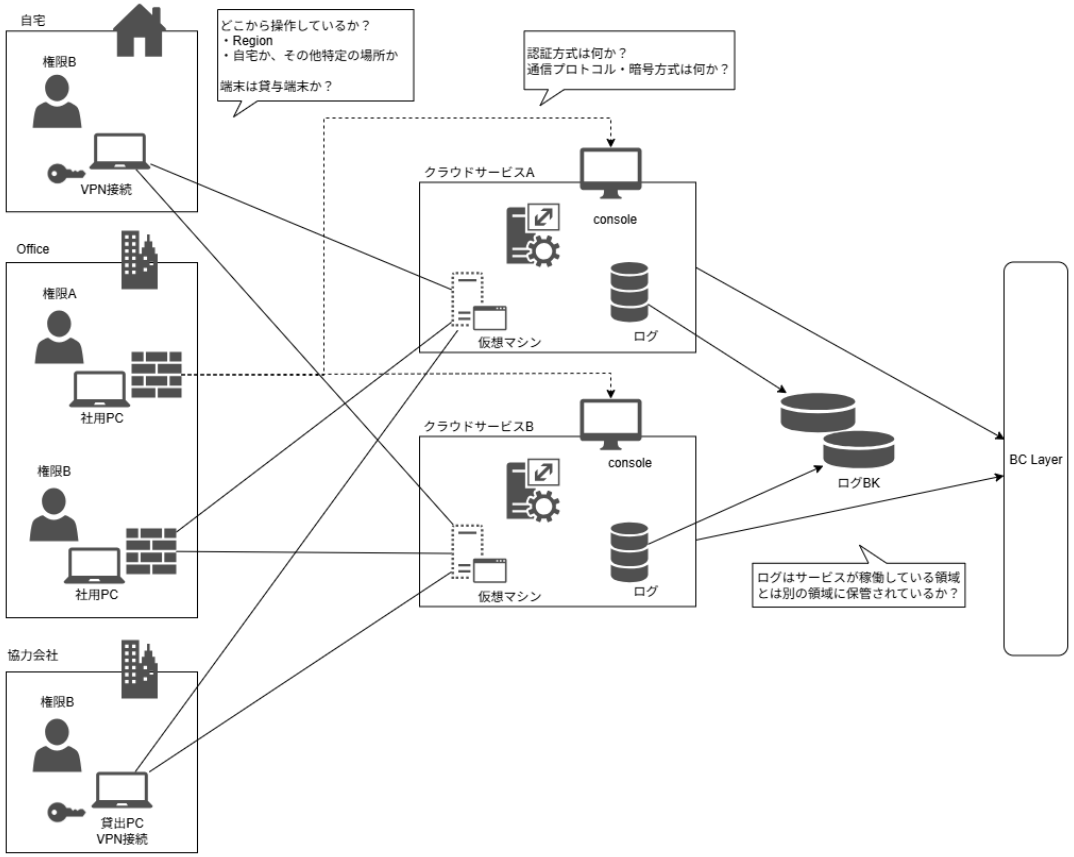
Standardized Checklist for Vendor Selection (Extract)

	A	B	C	D	E	F
1	#	Category (JPCrypto-ISA	Subcategory	Confirmation Item	Required Submission	Details to Provide / Required Information
2	1	2. Security Assessment	Technical Security Measures	System configuration (network separation, DMZ design, segmentation, etc.)	Submit a system diagram (refer to the sample "System Architecture" sheet) illustrating how your employees access the cloud environment.	
3	2	2. Security Assessment	Access Management and Ir	Security Management for Remote Work Environments	Confirm if Endpoint Detection and Response (EDR) and Mobile Device Management (MDM) solutions are in place.	
4	3	2. Security Assessment	Access Management and Inte	Internal Control and Access Management	Specify the department responsible for granting access to the cloud system, and the department or position that approves such access.	
5	4	2. Security Assessment	Access Management and Inte	Internal Control and Access Management	Indicate the frequency of reviewing account access privileges to the cloud system.	
6	5	2. Security Assessment	Access Management and Inte	Account authority management (privilege ID management, access key management, principle of minimum authority, periodic authority inventory, etc.)	Describe your internal management process for privileged IDs (e.g., root accounts).	
7	6	2. Security Assessment	Access Management and Inte	Account authority management (privilege ID management, access key management, principle of minimum authority, periodic authority inventory, etc.)	Explain how API keys and cloud access tokens are managed.	
8	7	2. Security Assessment	Access Management and Inte	Production system work approval process (application / approval flow, work record, emergency procedures, etc.)	Is there a workflow or ticket system where multiple people can approve and then deploy production environments?	
9	8	2. Security Assessment	Access Management and Inte	Production system work approval process (application / approval flow, work record, emergency procedures, etc.)	Submit evidence of production access and records of deployment approvals.	
10	9	2. Security Assessment	Access Management and Inte	Production system work approval process (application / approval flow, work record, emergency procedures, etc.)	Can the production environment be accessed from machines also used for general activities (internet browsing, email, social media)?"	
11	10	2. Security Assessment	Access Management and Inte	Control and log remote access	Provide information on the roles and remote access privileges of personnel involved in production operations.	
12	11	2. Security Assessment	Access Management and Inte	Control and log remote access	When accessing production environments remotely, describe the access controls in place for communication (e.g., IP address restrictions, VPN connections).	
13	12	2. Security Assessment	Access Management and Inte	Control and log remote access	When connecting to production environments via remote access, describe your monitoring systems (e.g., logging for abnormal time zones, unauthorized access attempts).	
14	13	3. Cyber Attack Countern	Countermeasures to Threat	Ransomware	Confirm that ransomware protection measures are implemented.	
15	14	3. Cyber Attack Countern	Countermeasures to Threat	Social Engineering Measures	Confirm that social engineering countermeasures are implemented.	

© JPCrypto-ISAC All Right Reserved.

Standardized System Architecture Diagrams

- Cloud architecture, access devices, and privilege information
- governance controls, not deep technical details like source code
- key management and access control
- transaction flow and signature process



© JPCrypto-ISAC All Right Reserved.

Standard Addendum to Master Service Agreements

- Audit rights
- Timely reporting
- Cooperation during regulatory inspections
- Mandatory incident reporting
- Standardized reporting format
- Vulnerability assessment test plan

ADDENDUM TO MASTER SERVICE AGREEMENT
ON
INFORMATION SECURITY

The Service Provider(“委託先の会社名”) and the User(“(“委託元の会社名”)”) agree as follows:

1. Definitions

1. Terms used in this addendum shall have the same meaning as those defined in the Terms of Service, unless otherwise specified.
2. In the event of any conflict between the provisions of this Addendum and the Terms of Service, the provisions of this Addendum shall prevail.

2. Service Provider's Security System

1. The Service Provider shall implement the measures described in the Security Checklist separately submitted to the User and shall maintain compliance with the items described in the Security Checklist throughout the service usage period.
2. The Service Provider shall notify the User within a commercially reasonable period of any significant operational changes, including the following items:
   (1) Updates to access policies relevant to the User's assets or services.
   (2) Changes in the location of developers or key personnel involved in critical systems related to the security of the custodial services provided.
   (3) Changes in key personnel responsible for the custodial services provided.
   (4) Other matters specified in the Security Checklist
      1. Changes in compliance with necessary regulatory requirements.

© JPCrypto-ISAC All Right Reserved.

JP Crypto-ISAC